HARDENING OPENSSH · 2026

# Mudei a porta do SSH. Estou seguro?

Spoiler: não. Você só ficou mais silencioso. Arraste para ver as 7 camadas que realmente protegem →

```
$ grep Port /etc/ssh/sshd_config
Port 49222
# isso sozinho não é segurança
```

O PROBLEMA

# Trocar a porta é obscuridade, não controle.

Ela tira o ruído dos bots do `auth.log` — e isso tem valor.
Mas quem mira no **seu** servidor faz isto:

```
$ nmap -sV -p- --min-rate 5000 alvo
PORT      STATE SERVICE VERSION
49222/tcp open  ssh     OpenSSH 9.6p1
# encontrado. próxima etapa: credenciais.
```

> Reduz **ruído**. Não reduz **risco**. Use como bônus — nunca como a defesa.

O MAPA

# SSH seguro é soma de camadas.

Se uma falhar, a próxima segura. Nenhuma depende do número da porta.

| | | |
|---|---|---|
| 01 | **Identidade** | só chave, sem root, allowlist |
| 02 | **Chaves fortes** | Ed25519 · FIDO2 · 2FA |
| 03 | **Força bruta** | limites + Fail2Ban progressivo |
| 04 | **Pivô** | sem forwarding, use ProxyJump |
| 05 | **Criptografia** | KEX pós-quântico, sem SHA-1 |
| 06 | **Rede** | VPN / bastion / allowlist |
| 07 | **Visibilidade** | logs, FIM, drift no SIEM |

01 · IDENTIDADE

# Quem entra — e como.

```
# /etc/ssh/sshd_config.d/00-hardening.conf
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
AuthenticationMethods publickey
AllowGroups ssh-users
```

- **Sem senha** = força bruta de senha vira inútil.
- **Sem root** = o atacante precisa adivinhar o usuário *e* escalar.
- **AllowGroups** = conta de serviço esquecida não loga por SSH.

02 · CHAVES FORTES

# Desligar senha só funciona com chave boa.

```
# padrão: Ed25519 com KDF reforçado + passphrase
$ ssh-keygen -t ed25519 -a 100

# melhor: chave de hardware FIDO2 (PIN + toque)
$ ssh-keygen -t ed25519-sk \
    -O resident -O verify-required
```

- A chave FIDO2 **não sai do token**: roubar o arquivo não basta.
- Sem token? Chave + **TOTP** via PAM.
- Frota grande? **Certificados SSH** com validade de horas.

03 · FORÇA BRUTA

# Menos tentativas, menos janela.

```
MaxAuthTries 3
LoginGraceTime 30
MaxStartups 10:30:60
ClientAliveInterval 300

# /etc/fail2ban/jail.d/sshd.local
mode = aggressive
bantime.increment = true
# reincidente: 1h → 2h → 4h … até 1 semana
```

Com senha desligada, o Fail2Ban vira **redução de ruído + telemetria** para o SIEM.

04 · PIVÔ

# Seu servidor não pode virar trampolim.

```
X11Forwarding no
AllowAgentForwarding no
AllowTcpForwarding no
PermitTunnel no
PermitUserEnvironment no
```

> **Agent forwarding** deixa quem tem root no servidor usar *sua* chave. Para saltar entre hosts, use `ProxyJump`: o bastion nunca toca na sua chave.

```
$ ssh -J bastion servidor-interno
```

05 · CRIPTOGRAFIA

# Algoritmos de 2026, não de 2006.

```
# 10-crypto.conf (OpenSSH ≥ 8.5)
KexAlgorithms sntrup761x25519-sha512@openssh.com,
  curve25519-sha256,…
Ciphers chacha20-poly1305@openssh.com,
  aes256-gcm@openssh.com,…
MACs hmac-sha2-512-etm@openssh.com,…
HostKeyAlgorithms ssh-ed25519,rsa-sha2-512,…
```

- **sntrup761**: híbrido pós-quântico contra "grave agora, decifre depois".
- Fora: CBC, SHA-1, `ssh-rsa`, DSA/ECDSA, moduli < 3072.
- Confira de fora com `ssh-audit`.

⚠ A PEGADINHA

# O OpenSSH usa a primeira ocorrência.

Em imagens de nuvem, o cloud-init pode religar a senha sem você ver:

```
$ ls /etc/ssh/sshd_config.d/
00-hardening.conf
50-cloud-init.conf  # PasswordAuthentication yes

# não audite o arquivo. audite o serviço:
$ sudo sshd -T | grep passwordauthentication
passwordauthentication no
```

> Prefixo **00-** faz o seu drop-in vencer. `sshd -T` mostra a config **efetiva**.

06 + 07 · REDE E VISIBILIDADE

# A melhor porta é a que ninguém alcança.

- **Rede:** SSH atrás de VPN ou bastion. Se exposto, allowlist + rate limit no firewall.

```
LogLevel VERBOSE
Accepted publickey for sl from 203.0.113.10
  ssh2: ED25519 SHA256:k3y…  ← qual chave entrou
```

**Alerte no SIEM:**

- mudança em `authorized_keys` → persistência (ATT&CK T1098.004)
- fingerprint fora do inventário · login de origem nova
- `sshd -T` com senha ligada → drift

ANTES DE APLICAR

# Hardening que te tranca para fora é incidente.

1. Mantenha uma sessão SSH **aberta**.
2. Valide com `sshd -t` antes de tudo.
3. Use `reload`, não `restart`.
4. Teste o login em **outro** terminal.
5. Tenha o console do provedor à mão.

```
# rede de segurança: rollback sozinho em 5 min
$ systemd-run --on-active=5min --unit=ssh-rollback …
$ systemctl stop ssh-rollback.timer   # deu certo
```

REPOSITÓRIO ABERTO

# Tudo isso pronto para usar.

```
$ sudo ./scripts/apply-hardening.sh
[+] Configuração válida.
$ sudo ./scripts/audit-ssh.sh
Resultado: 19/19 aprovados
```

- Drop-ins para `sshd_config.d/` + Fail2Ban + cliente
- Aplicação com backup, validação e rollback
- Auditor de 19 checagens — texto ou JSON p/ SIEM
- Docs: FIDO2, 2FA, firewall, detecção, checklist

**github.com/s3mPr1linux/SSH_HARDENING_2026**

Qual camada ainda falta no seu ambiente? Comenta aí 👇

Inspirado em "SSH seguro além da porta" — HelpSysAdmin